

Potential Regular Expression Denial of Service (ReDoS)

Assessment Identifier: **WS-STA-08** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 5.3	CWE: CWE-1333
OWASP: A03	WASC ID: N/A	Confidence: Medium candidate
Target / Component: server/shared components	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/server/shared/	Parameter: Dynamic regex pattern compiler

1. Description

Static analysis identified dynamically constructed regular expressions. The risk depends on whether untrusted input can influence the pattern and whether the resulting expression has excessive computational complexity.

2. Steps to Reproduce

1. Identify the dynamic regex construction.
2. Determine whether an attacker can influence the pattern.
3. Test only with bounded input in a local environment.
4. Measure execution time.
5. Determine whether processing grows disproportionately.

3. Controlled Proof of Concept

Safe Proof of Concept:
Use small, bounded local test strings and measure execution time. Do not send high-volume requests or intentionally overload a live system.

4. Business & Security Impact

A confirmed ReDoS condition could consume excessive CPU and degrade application availability.

5. Remediation Recommendations

Primary Fix: Prefer fixed regex patterns, avoid constructing regexes from untrusted input, limit input length, and use safe regex patterns.

1. Replace dynamic regex construction with static, pre-compiled regular expressions.
2. Audit expressions for nested quantifiers and overlapping subpatterns (catastrophic backtracking).
3. Use linear-time regular expression engines (such as re2) where user-supplied queries are permitted.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*